
Tutorial 8 Solution

Detecting and Preventing Intrusions

Computer Security BCS2420

Part A

1. **IDS vs. IPS**
Answer: 2. An IDS passively monitors... while an IPS can actively block or modify traffic.
 2. **Base Rate Problem**
Answer: 2. Most alarms raised will be false alarms in very low incidence scenarios.
 3. **Signature-Based IDS Limitation** **Answer:** 2. It can only detect known attack patterns... must be updated.
 4. **Specification-Based IDS** **Answer:** 3. Checks events against an explicit spec for allowed behavior.
 5. **Anomaly-Based IDS Pitfalls** **Answer:** 3. Profiles may not capture the entire normal range → many false positives.
 6. **Host-Based IDS** **Answer:** 2. Monitors OS logs, file integrity, etc. on a single host.
 7. **False Negative** **Answer:** 2. The system fails to detect a real intrusion.
 8. **Packet Sniffers** **Answer:** 1. Switches isolate traffic to intended ports, so promiscuous mode sees minimal traffic unless special measures are used.
 9. **DNS Cache Poisoning** **Answer:** 3. Insert false name-to-IP mappings in DNS cache.
 10. **ARP Spoofing** **Answer:** 2. Unsolicited ARP reply linking gateway IP to attacker's MAC.
-

Part B

1. Detecting DDoS

- *Techniques or Heuristics:*
 1. Flow-based detection analyzing anomalies in traffic patterns or distribution of source IPs.
 2. Correlation with known baseline profiles and rate-limits—if many concurrent connections from diverse IPs spike abnormally.
- They might also check if the incoming wave correlates to a legitimate campaign (flash crowd) via external signals like social media or logs.

2. Base Rate Fallacy

- With 100,000 events:
 - Attacks: 10 (1 in 10k).
 - Detected attacks = 95% of 10 => ~9.5.
 - Non-attacks = 99,990. 1% false positives => ~999.9 false alarms.
- So ~9 true positives vs. ~1000 false positives. The IDS yields an overwhelming false alarm rate, leading to "alarm fatigue."

3. Signature vs. Anomaly

- *Signature-based scenario:* e.g., a known vulnerability exploit (like a specific MS-SQL injection). It's best to quickly detect that known pattern.
- *Anomaly-based scenario:* zero-day attacks with unusual traffic patterns (like stealthy exfiltration). No signature yet, so anomaly detection might catch weird usage or novel processes.

4. Specification-Based IDS Complexity

- Time-intensive as experts manually define precise "allowed" behaviors.
- E.g., building a spec for a complex protocol like SIP (VoIP) or a large web application with numerous dynamic endpoints. Getting the specification correct is challenging.

5. Vulnerability Scanners

- *Systematic approach:* They test open ports, try known exploits, check versions for vulnerabilities in a large plugin library.
- *Limitations:* They might miss newly discovered zero-days

or raise false positives if they incorrectly identify a service version. Also, scanning can be risky if it disrupts fragile systems.

6. Mitigating ARP Spoofing

- *Solution 1:* Use static ARP mappings for critical devices. Downside: Maintenance overhead if network addresses or hardware changes frequently.
- *Solution 2:* Deploy 802.1X or dynamic ARP inspection (DAI) on switches. Potential drawback: Complex configuration or need for modern switch support.

7. DNS Cache Poisoning

- *Attacker method:* Sending forged DNS responses faster than the legitimate server, hoping to match the correct transaction ID or source port.
- *Countermeasures:*
 1. Randomizing source ports + transaction IDs.
 2. Use 0x20 randomization or DNSSEC for cryptographic authenticity.

8. SYN Flooding

- *Cause:* The attacker floods half-open TCP connections (SYNs) but never completes them, depleting server resources.
- *SYN cookies:* The server encodes essential connection info into the SYN-ACK's sequence number. No allocation needed until final ACK. This drastically reduces resource usage per half-open connection.

9. Smurf/Amplification

- *Amplification factor 100* means an ICMP echo request goes to a broadcast address with 100 responding hosts. Each reply goes to the victim's spoofed IP.
- *Mitigation:* Disallow directed broadcast at routers, so broadcast pings are dropped or do not forward.

10. IDS Evasion

- *Evasion Techniques:*
 - Fragmentation or unusual TCP segment ordering to slip past signature checks.
 - Polymorphic shellcode or encryption to hide exploit content.
- *Modern IDS defenses:* Reassemble or normalize streams, decode or decrypt known packers, compare multiple signature patterns across segments.

Part C

1. False Positives and Negatives

- 2% FPR, 90% TPR, daily events: 10,000 benign + 200 real intrusions.

1. **False negatives:** 10% of real intrusions $\Rightarrow 0.10 \times 200 = 20$ missed.

2. **False positives:** 2% of 10,000 benign $\Rightarrow 0.02 \times 10,000 = 200$.

2. Anomaly Alert Volume

- 1 million events/day, 200 attacks, 90% detection $\Rightarrow 180$ real detections.
- 2% false alarm on 999,800 benign $\Rightarrow 0.02 \times 999,800 = 19,996$ false alarms.
- *Total alarms* = $180 + 19,996 \approx 20,176$. Real = 180.

3. Base Rate

- 99% accuracy $\Rightarrow$ 1% error each way.
- Intrusions 0.1% $\Rightarrow$ for each 1000 events, 1 intrusion. Probability an alarm is real = typically well under 50% if the base rate is low. The intuitive result: even with high accuracy, many alarms are false if intrusions are rare.

4. DoS Bandwidth

- $100,000 \text{ pps} \times 512 \text{ bytes} = 51,200,000 \text{ bytes/s} = \sim 51.2 \text{ MB/s} = 409.6 \text{ Mb/s}$ (8 bits/byte). So **$\sim 410 \text{ Mbps}$** .
 - If target link is 100 Mbps, yes, it can saturate it.
-